

THE SECURITY & TRUST KIT

Vendor Discovery, Done Properly: The 4 Proofs to Demand Before You Sign

The evidence you must demand from every e-invoicing vendor in the UAE – before your invoice data becomes the government's source of truth.

In Vendor Discovery, Every Slide Says "Enterprise-Grade Security." Almost None Sign It.

The market has moved past feature comparisons. Every approved ASP claims the same scale, the same security, the same connectors. What actually separates vendors is no longer **what they claim**, it is **what they can evidence, and what they will put in writing**.

And the stakes are unusual. From **1 January 2027**, your e-invoices flow through your ASP to the FTA in real time. That makes your ASP the custodian of your most sensitive commercial data: every customer, every price, every margin, every dispute. A vendor security failure is not an IT incident. It is a **business exposure event**, visible to the regulator.

The rule of vendor discovery

If a security claim exists only in a demo or a slide, treat it as unverified. Every claim in this kit maps to a document you can hold, an audit you can read, or an SLA you can enforce. Ask every vendor for all four. Then ask for them signed.

What "Verified" Looks Like, in 4 Documents

- **The SER walkthrough** — an independent penetration test you can inspect, plus a data-handling sign-off that names who can touch your data, and when.
- **The certifications and audit record** — SOC 2 Type II, ISO 27001, encryption standards and audit cadence, with certificate numbers, not logos.
- **The data-residency note** — primary site, failover site, and a contractual commitment that data never crosses the UAE border.
- **The SLA sheet** — uptime, first-response and resolution times, backed by service credits, not goodwill.

Why this favours specialists

For a global software giant, your security questionnaire is a ticket in a queue. For ClearTax, compliance is the entire company, so security evidence is not assembled on request; it is the product. Everything in this kit is available today, in full, under NDA.

DOCUMENT 01

The SER Walkthrough

A Security Engagement Review is where claims meet evidence: an independent penetration test, plus a signed commitment on exactly how your data is handled.

- Has an **independent third party** performed Vulnerability Assessment & Penetration Testing (VAPT) on the platform, and can they walk you through the latest report, including what was found and fixed?
- Is testing **recurring** (annual or better, plus after major releases), or was it a one-time exercise for accreditation?
- Will they sign a **data-handling commitment**: who can access your data, under what roles, with what logging, and how access is revoked?
- Is access governed by **role-based access control (RBAC)** and are all API calls authenticated with tokens, or does "admin access" mean everyone?
- Will they complete **your** security questionnaire and sit for a review with your infosec team, or route you to a generic trust page?

THE CLEARTAX ANSWER

We run a structured SER with every enterprise prospect: a walkthrough of our latest independent VAPT report, our SOC 2 Type II audit findings, and our security architecture, with your infosec team in the room. Access to your data is governed by RBAC with granular permissions; every API call is token-authenticated; and we sign a data-handling commitment covering access, logging, retention and revocation, aligned with UAE PDPL privacy-by-design principles. Nothing is "available on request only." It is available in the first meeting, under NDA.

Red flag to watch

A vendor who shares a certificate but refuses to walk through the underlying report. Certificates say testing happened. The walkthrough tells you whether they understood the findings.

DOCUMENT 02

Certifications and Independent Audits

Certifications are table stakes, but only if they are current, independently audited, and cover the actual production platform. Ask for certificate scope and dates, not logos.

SOC 2 Type II

Security controls audited by an independent firm over time, not a point-in-time snapshot. The gold standard for operational security discipline.

ISO 27001:2022

Certified information security management system covering people, process and platform, on the current 2022 standard, not the retired 2013 one.

ISO 22301:2019

Business continuity certification: proof that failover, recovery and continuity plans are documented, tested and audited.

Independent VAPT

Regular third-party penetration testing and hardening, with reports you can review, not a self-assessment.

AES 256-bit at rest · SSL/TLS in transit

Strong encryption for stored data, and encrypted transmission for every invoice in motion, across every hop.

RBAC + Token-Authenticated APIs

Granular, role-based access to your data, and authenticated tokens on every API call. No shared credentials, no blanket admin.

THE CLEARTEXT ANSWER

ClearTax holds all of the above, current and independently audited: SOC 2 Type II, ISO 27001:2022, ISO 22301:2019, recurring independent VAPT, AES-256 encryption at rest, SSL-secured data in transit, RBAC and token-based API authentication, with privacy controls aligned to UAE PDPL. The same platform already carries **1B+ e-invoices annually for 5,000+ enterprises across 50+ countries**, so these controls are exercised at scale every day, not maintained for the audit.

What to check on any certificate

The certificate's scope (does it cover the e-invoicing platform you'll actually use?), the issue and expiry dates, and the auditing body. A logo without a scope statement is marketing, not assurance.

DOCUMENT 03

The Data-Residency Note

"Hosted in the UAE" can mean many things. The questions that matter: where is primary, where is failover, and does anything, including backups, ever cross the border?

- Is **production data** hosted inside the UAE, and, crucially, is the **disaster-recovery site also inside the UAE**? A local primary with a foreign failover is not data residency.
- Is the architecture **multi-cloud**, or does a single provider outage take your invoicing down with it?
- What are the committed **RTO and RPO**, and are they contractual?
- Do **backups and replication traffic** stay in-country, or do they quietly transit foreign regions?

PRIMARY · OCI ABU DHABI

Oracle Cloud Infrastructure, production workloads, UAE soil.

FAILOVER · AWS UAE (ME-CENTRAL-1) DUBAI

Independent cloud vendor, 3 availability zones, UAE soil, auto-sync with primary.

< 1 hr

Recovery Time Objective (same-region DR)

< 15 min

Recovery Point Objective

Zero

Cross-border data movement, production or backup

THE CLEARTAX ANSWER

100% UAE data sovereignty, enforced at the infrastructure layer. Our failover is local-to-local, Abu Dhabi to Dubai, across two independent cloud vendors, so a provider-level failure never becomes your compliance failure, and no production data or backup traffic ever leaves UAE jurisdiction. Delivered through a local UAE entity, aligned with UAE PDPL, and proven at scale: the same architecture processes **300M+ e-invoices annually on OCI in KSA**.

DOCUMENT 04

The SLA Sheet

An SLA without service credits is a wish. Ask every vendor to put numbers, and consequences, on paper.

COMMITMENT	THE NUMBER TO DEMAND	WHY IT MATTERS
Platform uptime	99.9%, contractual, backed by service credits and independently verified	Downtime means invoices don't move, and penalties compound daily under Cabinet Decision No. 106.
First response	Within 60 minutes for critical issues, 24x7, in-house, not an outsourced call centre	Message Level Status (MLS) gives your ASP a 10-minute response window on the Peppol network. A 5-day ticket queue is disqualifying.
Critical fix / workaround	Within 4 hours, with a named owner and a live observation tracker	Every hour a failure sits unresolved is AED 100 per invoice accumulating in the background.
Failed invoices	Auto-healing retries, deep validations, ASP-owned MLS resolution	Failures should be retried and resolved by the platform, not discovered by your team in a penalty notice.
Peak throughput	10,000 e-invoices/sec, 200–300 ms generation, proven at 100M+/month	Month-end and promo peaks are exactly when a weak platform fails, and when failure costs most.
Escalation	3-tier matrix agreed at kick-off, named CSM, leadership line, all the way to the CEO	The escalation path must exist before things go wrong, not be negotiated during the outage.

THE CLEARTAX ANSWER

Every row above is our standard commitment: a contractual 99.9% uptime SLA backed by service credits, 24x7 in-house support with a dedicated local CSM, a 3-tier escalation matrix agreed at implementation start, auto-healing retry logic with ASP-owned MLS resolution inside Peppol's 10-minute window, and, because e-invoicing is our entire business, a direct line to our CEO if you are ever unhappy. Ask any global platform to match that, in writing.

The bottom line for CFOs

Security and trust are not evaluated in a demo. They are evaluated in documents: a pen-test you can read, certifications with scope and dates, a residency note with no asterisks, and an SLA with credits attached. ClearTax will hand you all four, signed. Ask every other vendor to do the same.

Talk to our Expert →